

CiberConsulting S.L. - Plan de Respuesta a Incidentes y Playbooks Sectoriales

ID Actividad: 4.01 **Curso:** 2526 **Tarea:** 4.1 **Grupo:** G2 **Entorno de la Empresa:** Asesoría de autónomos y PYMEs (150 empleados, 2 sedes, web/tienda online externalizada).

Índice

1. [Introducción](#)
2. [Plan de respuesta](#)
3. [Playbooks](#)
4. [Respuesta a las preguntas](#)
 - [Pregunta 1.a \(Relación MITRE ATT&CK y RE&CT\)](#)
 - [Pregunta 1.b \(Playbooks identificados y flujo\)](#)
 - [Pregunta 1.c \(Cobertura de fases PICERL\)](#)
 - [Pregunta 2.a \(Flujo de Toma de Decisiones y Escalado\)](#)
 - [Pregunta 3.a \(Respuestas Resilientes\)](#)
5. [Conclusiones](#)
6. [Bibliografía](#)

Introducción

Este documento define el plan de respuesta a incidentes de CiberConsulting S.L. y los playbooks operativos asociados, ajustados al contexto real de la empresa: 150 empleados, dos sedes físicas y una web/tienda online externalizada. El objetivo es que, ante un incidente, el equipo pueda actuar de forma coordinada, rápida y verificable: confirmar el incidente, contenerlo, erradicar la causa, recuperar la operación y capturar lecciones aprendidas.

Para que el plan no sea genérico, el enfoque combina:

- Identificación de activos y criticidad (qué hay que proteger y con qué prioridad).
- Modelado de amenazas y técnicas (MITRE ATT&CK) para aterrizar “qué nos puede pasar”.
- Acciones defensivas concretas (RE&CT) para traducir la teoría en pasos ejecutables.
- Cobertura de ciclo de vida de respuesta (NIST SP 800-61 / PICERL) para asegurar que no se omiten fases.

El resultado se concreta en 6 playbooks que cubren los escenarios de mayor impacto/probabilidad para la organización (exfiltración web, phishing, ransomware, acceso no autorizado, compromiso de proveedores y pérdida/robo de dispositivo), con evidencias de flujo (diagramas) y guías de actuación.

Inventario de activos

ID	Activo	Tipo	Categoría	Propietario	Valor C	Valor I	Valor D	Criticidad
ACT-001	Datos personales (RGPD)	Datos	Clientes / Legal	Director Legal	5	5	4	Alta
ACT-002	Página web / Tienda online	Servicio	Ventas / Marketing	Director Comercial	4	5	5	Alta

ID	Activo	Tipo	Categoría	Propietario	Valor C	Valor I	Valor D	Criticidad
ACT-003	Aplicaciones empresariales (CRM/ERP)	Software	Procesos / Operaciones	Director TIC	4	4	5	Alta
ACT-004	Servidores de Archivos (Local)	Hardware/SW	Almacenamiento	Director TIC	4	4	4	Media
ACT-005	Propiedad intelectual (Informes)	Datos	Negocio / Legal	Dir. General	5	4	3	Media
ACT-006	Dispositivos Móviles (Portátiles/Tabletas)	Hardware	Empleados	Director RRHH	3	3	3	Media
ACT-007	Personal cualificado	Persona	RRHH	Director RRHH	5	4	4	Media
ACT-008	Servidores de Correo Electrónico (Local)	Servicio	Comunicaciones	Director TIC	4	4	4	Media

Plan de respuesta

[Estructura general del Plan de Respuesta y asignación de roles técnicos de CiberConsulting S.L.]

Playbooks

Aquí se listan los 6 playbooks detallados creados por el equipo:

- [Playbook 1: Exfiltración de Datos \(Web/Tienda Online\)](#)
- [Playbook 2: Ataque de Phishing](#)
- [Playbook 3: Infección por Ransomware](#)
- [Playbook 4: Acceso No Autorizado \(Físico y Lógico\)](#)
- [Playbook 5: Compromiso de la Cadena de Suministro / Proveedores](#)
- [Playbook 6: Pérdida o Robo de Dispositivo](#)

Respuesta a las preguntas

1.a ¿Qué relación existe entre el trabajo que has hecho con las matrices MITRE ATT&CK y RE&CT y el plan de respuesta que estás planteando? ¿De qué manera te ha ayudado el trabajo previo?

De una defensa genérica a una respuesta activa

En realidad, lo importante de MITRE ATT&CK y RE&CT es que funcionan juntas. ATT&CK te dice qué te puede atacar específicamente (según tu sector, infraestructura y contexto), y RE&CT te dice cómo defenderte contra eso de forma concreta. Para CyberConsulting, esto significa pasar de tener un plan defensivo genérico ("protegemos todo") a un plan que realmente funciona ("ante esto, hacemos esto otro").

Qué nos puede pasar y por qué

CyberConsulting no es una empresa normal. Tenemos 150 empleados, 2 sedes físicas, y la tienda online está alojada en un servidor que no controlamos. Eso significa que hay riesgos muy específicos que nos van a atacar:

1. Ataque a la tienda online (T1190 - Exploit Public-Facing Application)

Nuestra tienda está fuera de nuestro control, en un servidor de terceros. Un atacante puede buscar vulnerabilidades en el CMS, plugins desactualizados o fallos de configuración. Por eso tenemos el playbook de exfiltración de datos específicamente para la web. Cuando investigamos, lo primero que miramos es si hubo accesos raros en los logs del servidor, si descargaron datos en grandes volúmenes, y si hay señales de inyección SQL o webshells.

2. Phishing y robo de contraseñas (T1598 / T1566 - Phishing, T1110 - Brute Force)

Uno de nuestros mayores riesgos es que nuestros empleados reciben mails de clientes, proveedores, administraciones públicas. Un atacante puede meterse en el correo de un admin y acceder a todo. Por eso tenemos un playbook específico para phishing que te dice cómo analizar si un correo es legítimo, si la gente lo abrió, y si alguien entró en sistemas. Cuando pasa, lo que hacemos es bloquearlo directamente en el servidor de correo, desactivar la sesión del usuario, y forzar que cambie la contraseña.

3. Ransomware (T1486 - Data Encrypted for Impact, T1008 - Fallback Channels)

Este es probablemente el que más nos asusta. Si alguien nos encripta los datos, no podemos facturar, no podemos trabajar con los clientes, se nos cae el negocio. Nuestro playbook para ransomware está bastante enfocado en parar el ataque rápido: aislar los sistemas infectados, bloquear el comando y control del atacante, proteger las copias de seguridad. Es la fase donde más rápido tenemos que actuar.

4. Acceso no autorizado (T1078 - Valid Accounts, T1098 - Account Manipulation)

Alguien entra sin permiso. Puede ser un técnico que se aprovecha, un ex-empleado que mantiene acceso, o alguien de fuera. En CyberConsulting tenemos oficinas donde entran personas externas (limpiadores, técnicos, visitantes). Además, manejamos credenciales compartidas que a veces quedan activas de más. Nuestro playbook mira los logs de quién entró cuándo, desde dónde, y qué hizo una vez dentro.

5. Compromiso de proveedores (T1195 - Supply Chain Compromise)

Nosotros no controlamos todo lo que usamos. La tienda está en un servidor de terceros, usamos Microsoft 365 para correo, tenemos herramientas en la nube, y los técnicos de mantenimiento entran a nuestras sedes. Si uno de nuestros proveedores se ve comprometido, nosotros también estamos en riesgo. Por eso tenemos un playbook que te dice cómo determinar si el problema vino de adentro o de un proveedor, y qué hacer en cada caso.

Cómo juntamos ATT&CK y RE&CT

RE&CT es básicamente la respuesta de ATT&CK. Cada tipo de ataque tiene una forma de defenderlo. Por ejemplo, si alguien está robando cuentas de usuario, RE&CT te dice que bloquee esa cuenta. Si hay ransomware, te dice que aisles la red. Si necesitas recuperar datos, te dice cómo restaurar desde backup.

Por ejemplo, imagina que descubrimos ransomware:

1. ATT&CK dice: alguien está cifrando nuestros archivos (T1486)
2. RE&CT dice: bloquea la red donde está infectado, corta la comunicación del atacante, restaura desde backup limpio
3. Nuestro playbook va directamente a hacer eso, sin perder tiempo

Por qué esto importa para nosotros

Gracias a esto, no tenemos un plan genérico que "protege todo". Tenemos un plan específico que sabe qué puede pasarnos y qué hacer. Sabemos exactamente los 6 playbooks que necesitamos (no más, no menos). Sabemos qué es prioritario en cada incidente (parar el ataque primero, investigar después). Y sabemos si nuestro plan funciona o no porque tenemos objetivos claros.

1.b ¿Qué playbooks has identificado como necesarios en este plan de respuesta y en qué te has basado para saber que son los necesarios? Deja algún diagrama que describa el flujo de un playbook.

Qué playbooks necesitamos y por qué

Para identificar los playbooks, no fue complicado. Miramos qué nos puede pasar basándonos en cómo es CyberConsulting, el historial de ataques en empresas como la nuestra, y qué podemos hacer realmente. Al final, sacamos 6 playbooks que cubren los riesgos reales.

Playbook 1: Exfiltración de Datos (Web/Tienda Online)

La tienda está en un servidor que no controlamos. Tiene datos de clientes, tarjetas, cuentas bancarias. Si alguien la ataca, nos roba eso. Es muy delicado porque si roban datos personales, tenemos 72 horas para notificarlo a la autoridad por RGPD. Este playbook es sobre parar rápido el ataque y mirar qué se llevaron.

Playbook 2: Ataque de Phishing

Nuestros empleados reciben muchos mails de fuera. Un atacante puede hacerse pasar por un cliente, un proveedor, o la administración pública. Si alguien hace clic, entrega credenciales o aprueba MFA, el atacante puede escalar a correo, nube y aplicaciones internas. Este playbook guía el análisis del mensaje, el alcance y la contención rápida (bloqueo/purga de correos, revocación de sesiones/tokens, etc.).

Playbook 3: Ransomware

Un ataque de ransomware nos para el negocio directamente. Si alguien nos encripta los datos, no facturamos, no trabajamos con clientes, se nos cae todo. Es el más peligroso. Lo que hacemos es aislar los sistemas rapidísimo, proteger las copias de seguridad para que no las encripten también, y bloquear al atacante.

Playbook 4: Acceso No Autorizado (Físico y Lógico)

En nuestras oficinas entran técnicos, gente de limpieza, visitantes. Cualquiera podría conectar un USB malicioso, robar datos en físico, o acceder a un equipo. Además, a veces la gente se va de vacaciones y deja la sesión abierta. Este playbook cubre ambas cosas: acceso físico y acceso lógico sin permiso.

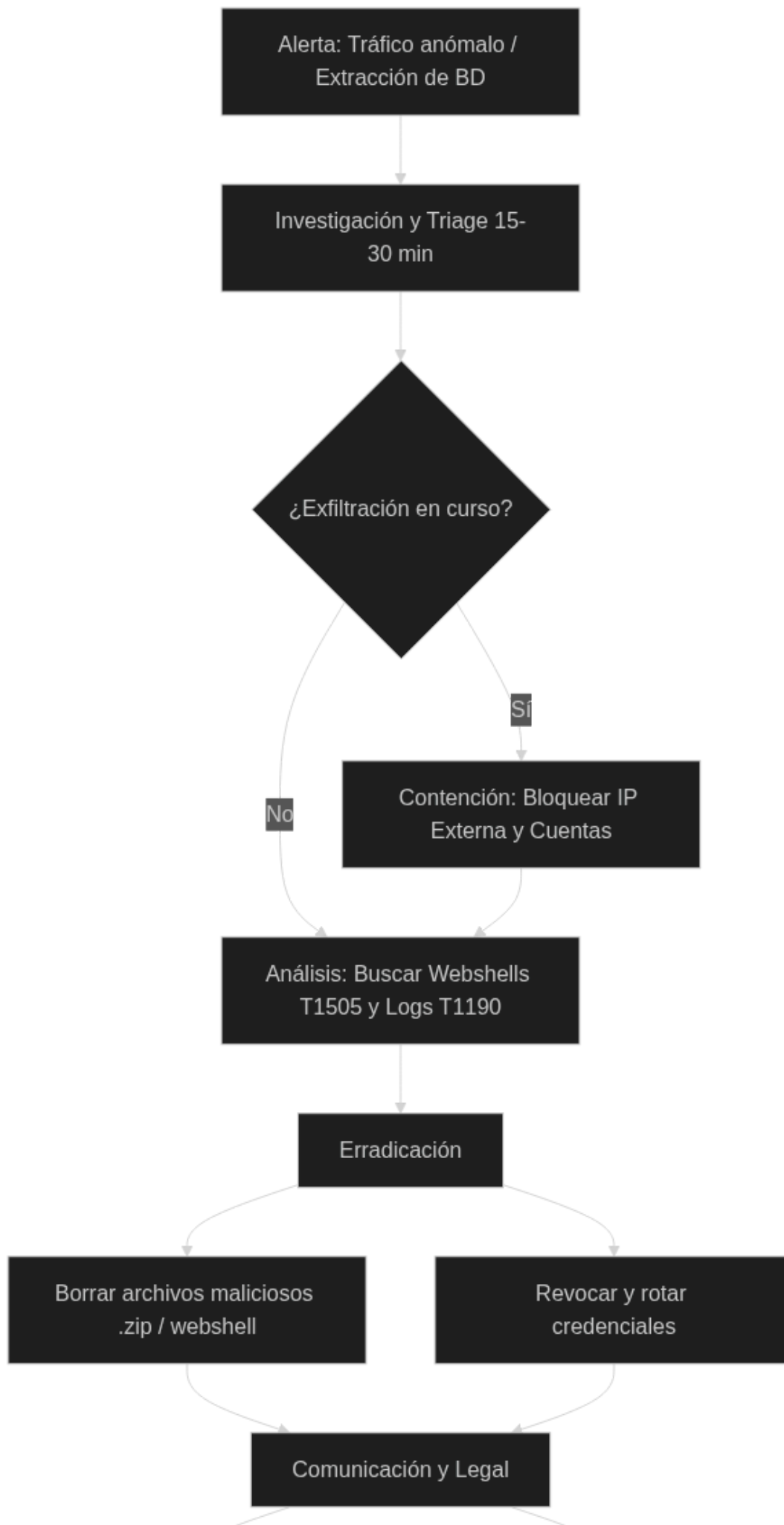
Playbook 5: Compromiso de la Cadena de Suministro / Proveedores

Usamos Microsoft 365, CRM en la nube, hosting de terceros. No controlamos sus servidores. Si uno de ellos se ve comprometido, nosotros también estamos en riesgo. Necesitamos saber si el problema es nuestro o del proveedor, y actuar en consecuencia.

Playbook 6: Pérdida o Robo de Dispositivo

Usamos portátiles, móviles y tabletas. Si se pierde o roba un dispositivo, el riesgo no es solo el hardware: puede implicar exposición de datos, sesiones activas, credenciales guardadas y acceso a almacenamiento en la nube. Este playbook define acciones rápidas de bloqueo/contención (revocación de sesiones, rotación de credenciales, MDM si aplica) y verificación de accesos anómalos.

Diagrama de Flujo: Playbook de Exfiltración de Datos (Web/Tienda)



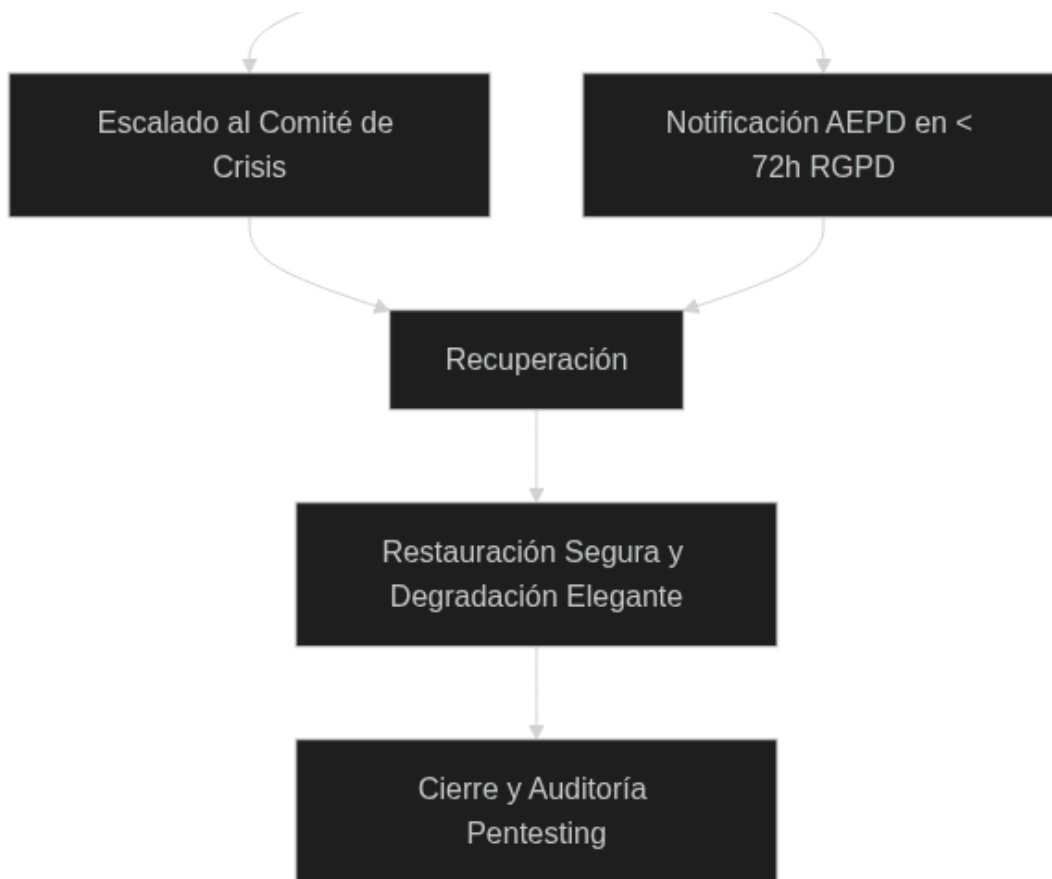
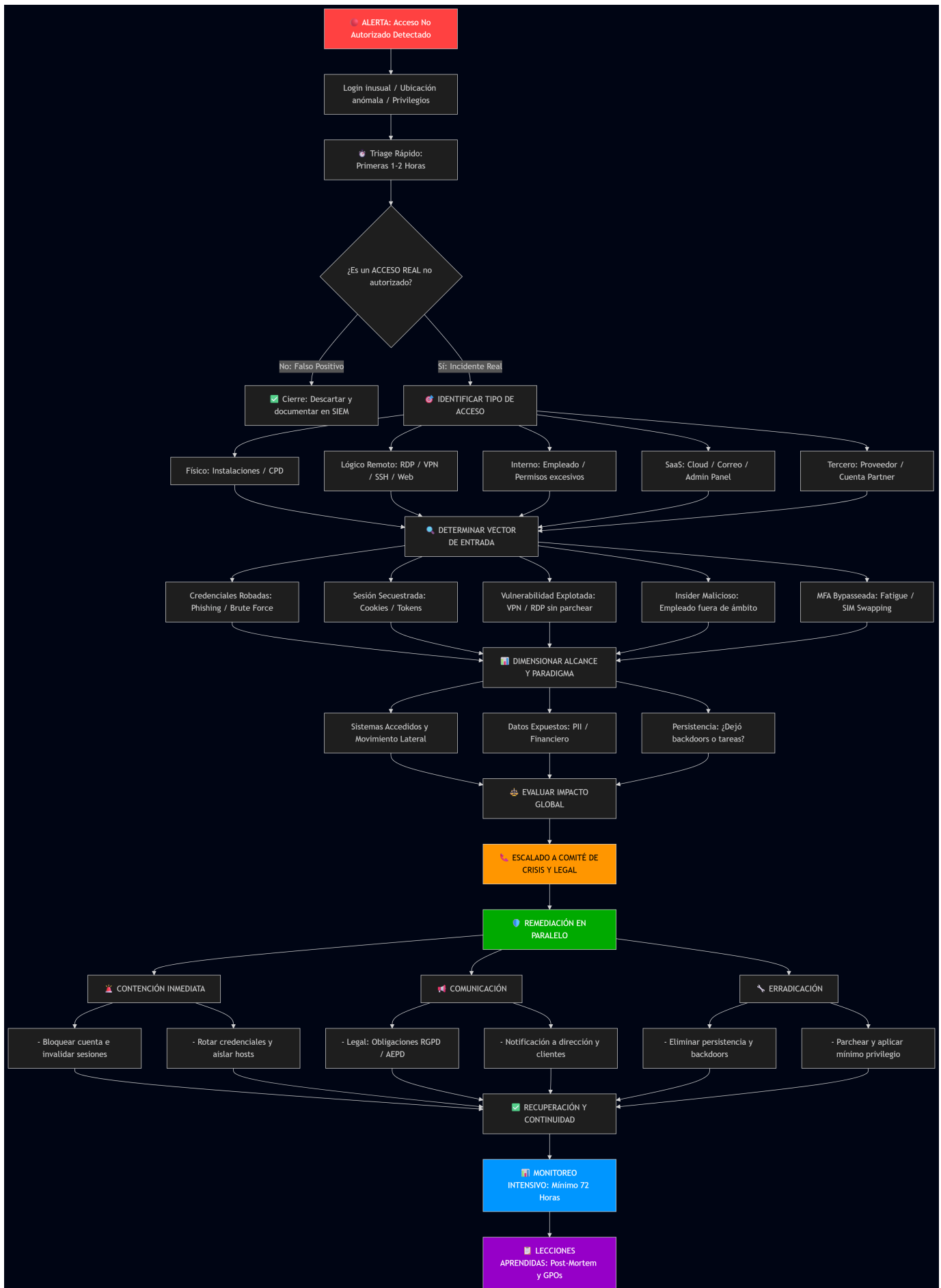


Diagrama de Flujo: Playbook de Acceso No Autorizado



1.c ¿Cómo te has asegurado que has cubierto todas las fases del plan de respuesta? ¿Qué fase consideras que está más floja en un plan? ¿Cuál de ellas consideras que está mejor trabajada en tu plan?

Cómo cubrimos todas las fases

Nuestro plan sigue las 6 fases del NIST SP 800-61. Básicamente es un círculo: te preparas antes, detectas cuando pasa algo, lo paras lo antes posible, lo cierras del todo, lo arreglas, y luego aprendes de qué pasó.

PREPARACIÓN: Antes de que pase nada

Aquí es donde tenemos documentados los roles (Incident Commander, ayudante, personas que escriben notas), los teléfonos para llamar, el chat donde hablan todos, las herramientas que usamos (SIEM, antivirus, etc.). Todo preestablecido para no perder tiempo cuando pase algo.

El problema aquí es que sobre el papel está bien, pero en la práctica no. No tenemos políticas de seguridad por escrito (qué contraseña es válida, cada cuánto cambiarla). No hacemos ejercicios de phishing fake para entrenar a la gente. No probamos si nuestras copias de seguridad funcionan realmente. Si pasa un incidente, nos vamos a dar cuenta de que muchas cosas no están lista.

IDENTIFICACIÓN: Algo pasó, pero ¿qué?

Cada playbook comienza mirando si es real o falso positivo. Por ejemplo, si alguien hace clic en un phishing, confirmamos que pasó. Si hay ransomware, miramos qué tipo es. En todos los playbooks, la gente tiene 15-30 minutos para confirmar de verdad que es un incidente.

Aquí estamos bastante bien. Tenemos procedimientos claros para cada tipo de ataque. Sabemos qué mirar en los logs, qué preguntar.

CONTENCIÓN: Parar esto ahora

Aquí es donde estamos mejor. Cuando descubrimos ransomware, no esperamos a terminar la investigación. Aislamos los sistemas infectados, bloqueamos el comando que controla el malware, protegemos las copias de seguridad. Cuando hay phishing, bloqueamos el correo, desactivamos la sesión del usuario, forzamos cambio de contraseña.

La idea es parar la propagación en las primeras 2-4 horas. Porque en un ransomware, cada minuto que dejas pasar, se infectan más sistemas.

ERRADICACIÓN: Que no vuelva

Aquí eliminamos cualquier rastro del atacante. Parches en sistemas. Eliminar acceso backdoor. Cambiar todas las contraseñas. En un ransomware, reinstalamos desde cero si es necesario.

Lo tenemos documentado, pero faltaría ser más específico sobre qué herramientas usar exactamente para eliminar webshells o malware.

RECUPERACIÓN: Arreglemos esto

Validamos que las copias de seguridad están limpias. Restauramos datos. Bajamos los sistemas poco a poco para no volver a infectar. Verificamos que no hay reinfección.

Lo que nos faltaría aquí es un plan más claro sobre cómo degradar elegantemente. Si no podemos levantar todo en 1 hora, ¿qué levantamos primero? ¿Qué puede funcionar parcialmente?

LECCIONES APRENDIDAS: Qué salió mal

Después de un incidente hacemos una reunión donde miramos qué pasó de verdad, qué se suponía que pasaría, y qué podemos mejorar. Esto está bien documentado. Hacemos una reunión con los responsables, escribimos qué aprendimos, y lo comunicamos a quien corresponde.

Donde fallamos y donde estamos bien

La fase más débil: Preparación

En la preparación es donde más nos falta. Sobre el papel tenemos todo bonito, pero en la realidad CyberConsulting no está preparada.

Lo primero es que no tenemos políticas de seguridad escritas. No existe un documento que diga "las contraseñas tienen que tener 12 caracteres y cambiarlas cada 90 días". No hay política de uso aceptable para empleados. No sabemos si el que se conecta por VPN tiene que usar MFA o no.

Segundo, no entrenamos a la gente. No hacemos ataques de phishing fake para entrenar. El help desk no sabe cómo es el triage de un incidente. Si alguien llama diciendo "creo que me hackearon", probablemente no sabrán qué hacer.

Tercero, nunca probamos el plan. No hacemos simulacros. Cuando un incidente real pase, nos vamos a dar cuenta de que nuestros canales de comunicación no funcionan o que las copias de seguridad no se pueden restaurar en 2 horas como esperamos.

Y cuarto, no sabemos bien qué sistemas son críticos y qué datos son sensibles. En `info.yml` hay placeholders que nunca completamos.

Donde estamos bien: Contención

Contención es lo que mejor tenemos hecho. Aquí es donde el plan realmente brilla.

En cada playbook, cuando detectamos un ataque, sabemos exactamente qué hacer sin esperar. En ransomware no esperamos a terminar la investigación. Aislamos inmediatamente, bloqueamos el comando del atacante, protegemos los backups. En phishing bloqueamos el correo, desactivamos sesiones, forzamos cambio de contraseña.

Todas las acciones están vinculadas a técnicas de respuesta de RE&CT. Eso significa que además pueden automatizarse con scripts.

Tenemos claros los escenarios: si un admin pierde su cuenta, sabemos que el atacante puede entrar a todo, entonces actuamos distinto a si pierde la cuenta un empleado normal.

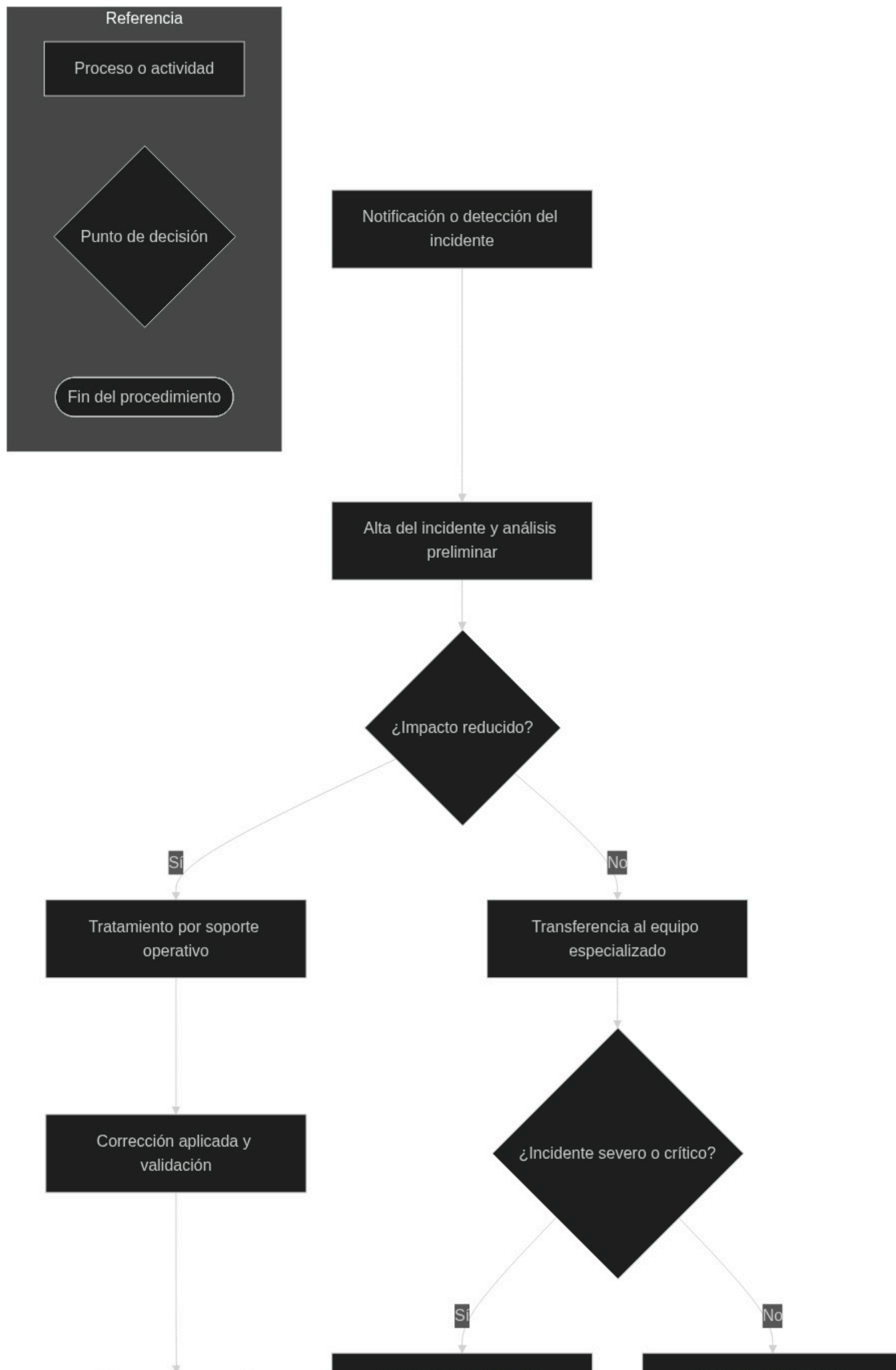
Y lo más importante: el plan dice específicamente qué hacer. No dice "aislar sistemas". Dice "cuarentena lógica del servidor X, del usuario Y, del almacenamiento compartido Z". Eso es lo que necesitas en un incidente real.

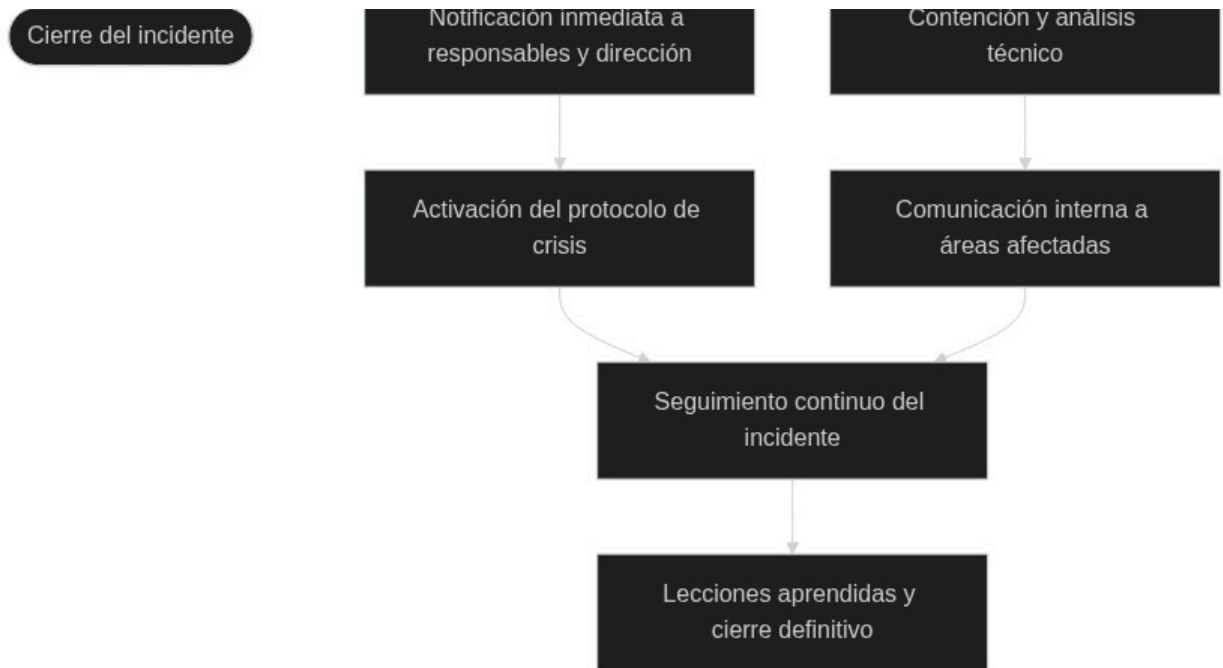
Resumen de cómo cubrimos cada fase

Fase	¿Está cubierta?	Qué tal está	Notas
Preparación	Parcial	Flojo (2/5)	Falta políticas por escrito, entrenamientos, pruebas
Identificación	Sí	Muy bien (5/5)	Procedimientos claros, triage rápido, decisiones definidas
Contención	Sí	Muy bien (5/5)	Acciones específicas, RE&CT vinculadas, automatizable
Erradicación	Sí	Bien (4/5)	Documentado pero sin herramientas específicas
Recuperación	Sí	Bien (4/5)	Falta plan más claro de degradación elegante

Fase	¿Está cubierta?	Qué tal está	Notas
Lecciones Aprendidas	Sí	Bien (4/5)	Proceso AAR bien estructurado, comunicación clara

2.a ¿En qué consiste el Flujo de Toma de Decisiones y Escalado de tu plan de respuesta? ¿Existe un plan de comunicación, protocolos, etc? Si la respuesta es correcta, haz un resumen del plan y protocolos. Deja evidencias del flujo, mediante un diagrama.





El flujo de toma de decisiones se basa en un proceso escalonado y documentado:

- Alerta inicial: detección de un incidente posible por phishing, acceso no autorizado, ransomware, exfiltración o compromiso de proveedor.
- Triage rápido: evaluación en las primeras 1-2 horas para distinguir falso positivo de incidente real.
- Identificación: determinar el tipo de incidente, vector de entrada y alcance del daño.
- Dimensionamiento: estimar sistemas afectados, datos expuestos, persistencia y movimiento lateral.
- Escalado: activar comité de crisis, legal y dirección según el impacto; notificar a clientes y reguladores cuando corresponda.
- Remediación en paralelo: contención inmediata, comunicación coordinada, erradicación técnica y recuperación controlada.
- Monitoreo intensivo: vigilancia activa durante al menos 72 horas tras la acción inicial.
- Lecciones aprendidas: reunión AAR para documentar causas, fallos y mejoras.

El plan incluye un protocolo de comunicación y roles predefinidos:

- Roles: Incident Commander, deputy, scribe, experto y liaison.
- Canales: chat de incidente, teléfono de crisis, correo de notificación y reuniones de escalado.
- Protocolos operativos: bloquear cuentas, desactivar sesiones, cuarentena lógica de servidores, protección de backups, cambio forzado de credenciales, aislamiento de redes, notificación RGPD/AEPD cuando sea necesario.
- Playbooks específicos: cada tipo de incidente tiene instrucciones concretas (phishing, ransomware, acceso no autorizado, exfiltración, proveedor comprometido).

3.a ¿Cómo te has asegurado de que tu plan tiene respuestas resilientes? ¿Por qué son resilientes y en qué fases se centran?

El plan se asegura de ser resiliente porque no es solo una respuesta aislada, sino un ciclo completo basado en NIST SP 800-61:

- Preparación: roles definidos, canales de comunicación preparados, herramientas y playbooks listos.
- Identificación: detección rápida, triage estructurado y clasificación del incidente.
- Contención: acciones inmediatas y específicas para detener la propagación, proteger backups y aislar sistemas.
- Erradicación: eliminación de rastros del atacante, parches, revocación de accesos y cambio de credenciales.
- Recuperación: restauración ordenada de servicios, validación de copias de seguridad y control de reinfección.
- Lecciones aprendidas: análisis post-incidente para ajustar el plan.

Son resilientes porque combinan:

- decisiones rápidas y bien definidas,
- protocolos concretos escritos en los playbooks,
- comunicación estructurada con escalado claro,
- enfoque en contención y recuperación paralelas.

Las fases más centradas en resiliencia son:

- Contención: es la más fuerte y mejor trabajada del plan.
- Recuperación: busca restaurar sin reinfectar y establecer continuidad controlada.
- Lecciones aprendidas: garantiza que el plan se mejore tras cada incidente.

Conclusiones

El plan y los playbooks entregan una respuesta aplicable a la realidad de CiberConsulting S.L., evitando un documento “teórico” y priorizando decisiones y acciones que se pueden ejecutar bajo presión. La parte más sólida del trabajo es la contención: para los escenarios críticos (ransomware, phishing y exfiltración) se definen medidas inmediatas que reducen impacto y limitan la propagación, y se conectan con ATT&CK/RE&CT para que sean trazables y, potencialmente, automatizables.

Las principales conclusiones del proyecto son:

- El plan queda acotado a 6 playbooks alineados con el riesgo real y los activos más sensibles, lo que facilita entrenar, mantener y ejecutar.
- El enfoque ATT&CK + RE&CT ayuda a pasar de “qué podría ocurrir” a “qué hacemos exactamente”, mejorando consistencia y repetibilidad.
- La fase más débil identificada es Preparación: faltan políticas por escrito, entrenamiento operativo y validación periódica (simulacros y pruebas de restauración de copias).
- Para aumentar la resiliencia, el siguiente paso no es añadir más playbooks, sino mejorar la ejecución: ejercicios de mesa, checklist de comunicaciones, y verificación de tiempos objetivo (MTTD/MTTC/MTTR) por escenario.

Bibliografía

Marcos y guías

- [MITRE ATT&CK](#) (matriz y técnicas enlazadas a lo largo de los playbooks)
- [MITRE RE&CT \(Response Actions\)](#)
- [NIST SP 800-61 Rev. 2: Computer Security Incident Handling Guide](#)
- [NIST Digital Identity Guidelines \(SP 800-63 - familia\)](#)
- [NIST SP 800-63B: Digital Identity Guidelines – Authentication](#)
- [NIST SP 800-124r2: Guidelines for Managing the Security of Mobile Devices in the Enterprise](#)
- [NIST SP 800-161r1: Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations](#)
- [NIST SP 800-218: Secure Software Development Framework \(SSDF\)](#)

Organismos y recursos

- [INCIBE: Gestión de incidentes de seguridad](#)
- [INCIBE: Phishing \(orientación al usuario\)](#)
- [INCIBE: Robo o pérdida de dispositivos móviles en la empresa](#)
- [CCN-CERT: guías y recursos \(España\)](#)
- [AEPD: Guía para la notificación de brechas de datos personales \(PDF\)](#)
- [RGPD Art. 33 – Notificación a la autoridad de control](#)

- [CISA: Report Phishing](#)
- [CISA: Cybersecurity Advisories \(incluye supply chain\)](#)
- [ENISA: Phishing \(panorama y recomendaciones\)](#)
- [ENISA: Threat Landscape 2023](#)
- [ENISA: Guidelines for SMEs on the Security of Personal Data Processing](#)
- [ENISA: Smartphone Secure Development Guidelines](#)
- [NCSC \(UK\): Phishing](#)
- [FBI IC3: Report Internet Crime](#)

Estándares y buenas prácticas (correo)

- [RFC 5322: Internet Message Format](#)
- [DMARC \(RFC 7489\), SPF \(RFC 7208\) y DKIM \(RFC 6376\)](#)
- [ICANN: IDN / Homograph attacks \(conceptos\)](#)

Herramientas y recursos operativos (citados en playbooks)

- [VirusTotal](#)
- [urlscan.io](#)
- [Google Admin Toolbox: Messageheader](#)
- [Microsoft: Message Header Analyzer \(MHA\)](#)
- [Reverse WHOIS \(Whoxy\)](#)
- [No More Ransom!](#)
- [ID Ransomware](#)
- [Microsoft: Consent phishing \(mitigación\)](#)
- [CISA: Implementing Phishing-Resistant MFA](#)
- [OWASP: Authentication Cheat Sheet](#)
- [CIS Controls](#)
- [Apple: Find My](#)

Supply chain (recursos adicionales citados)

- [SLSA: Supply-chain Levels for Software Artifacts](#)
- [OWASP: Software Supply Chain Security](#)
- [CNCf: Software Supply Chain Best Practices](#)

Lecturas complementarias citadas

- [GDATA: Ransomware Identification for the Judicious Analyst](#)
- [Ejemplos de correos de phishing \(Phishing.org\)](#)
- [SecurityMetrics: 7 ways to recognize phishing emails](#)
- [InfoSec Institute: Anti-phishing resources y best practices](#)